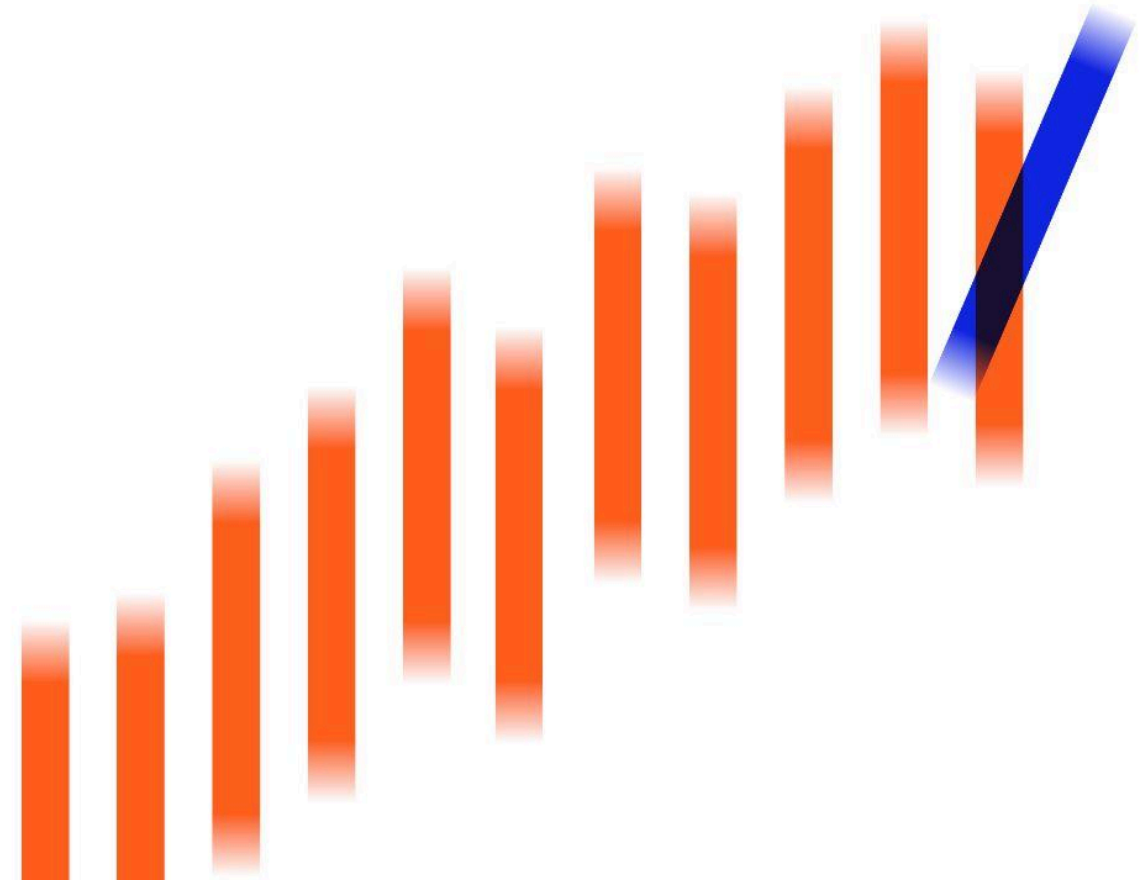
Politique de Sécurité des Systèmes d'Information



logiclever
Free to do better

1. Préambule **3**
1.1 Objet de la politique 3
1.2 Domaine d'application 3
1.3 Référentiels 4
1.4 Engagement de la direction 4
1.5 Objectif de certification 4
2. Gouvernance et organisation SSI **4**
2.1 Définition des rôles et responsabilités 4
2.2 Formalisation et diffusion de la politique SSI 5
2.3 Comité de pilotage de la sécurité 5
2.4 Plan de traitement des risques 5
2.5 Inventaire et classification des actifs 6
3. Protection des données à caractère personnel **6**
3.1 Intégration du RGPD dans la politique SSI 6
3.2 Désignation du Délégué à la Protection des Données (DPO) 7
3.3 Principes de traitement des données personnelles 7
3.4 Cartographie des traitements et responsabilités 7
3.5 Politique de minimisation des données 8
3.6 Exercice des droits des personnes 8
3.7 Procédure de notification en cas de violation 8
3.8 Formation et sensibilisation RGPD 9
3.9 Effacement et suppression des données 9
4. Sécurité des utilisateurs et Ressources Humaines **9**
4.2 Signature d'engagements de confidentialité 10
4.3 Attribution et révocation des accès 10
4.4 Sensibilisation et formation des utilisateurs 11
4.5 Politique de gestion des mots de passe 11
4.6 Authentification forte (MFA) 12
4.7 Politique BYOD (Bring Your Own Device) 12
5.1 Chiffrement des données au repos et en transit 12
5.2 Cloisonnement des réseaux et filtrage des flux 13
5.3 Isolation des données clients 13
5.4 Gestion et destruction des supports physiques 13
5.6 Sauvegardes et archivage 13
5.7 Continuité des opérations 14
5.8 Politique de gestion des vulnérabilités 14
5.9 Politique de gestion des correctifs de sécurité (patchs) 15
5.10 Identification et retrait des systèmes obsolètes et Shadow IT 16
6. Sécurité dans les projets et développements **16**

6.1 Intégration de la sécurité dès le cadrage projet 16
6.2 Intégration de la sécurité dans le cycle de vie projet 17
6.3 Développement sécurisé (le cas échéant) 17
6.4 Formation des équipes projets 17
6.5 Tests de sécurité avant mise en production 18
7. Exploitation et infrastructures 18
7.1 Gestion des changements 18
7.2 Plan de gestion de la capacité 19
7.3 Protection de la messagerie électronique 20
7.4 Contrôle des accès physiques 20
7.6 Journalisation des activités sur les applications 21
7.7 Protection et intégrité des journaux 22
7.8 Sécurité du réseau 22
7.9 Sécurité des postes de travail 23
7.10 Surveillance et détection des comportements anormaux 24
7.11 Sécurité des supports de stockage amovibles 24
7.11 Règles de gestion des clés de chiffrement 25
7.12 Stockage séparé des clés de chiffrement 25
7.13 Politique de bureau propre (Clean Desk Policy) 26
7.14 Suppression sécurisée des fichiers et supports 27
7.15 Conformité réglementaire des transferts de données 27
8. Gestion des incidents de sécurité 28
8.1 Détection et signalement des incidents 28
8.2 Qualification et journalisation des incidents 29
8.3 Traitement opérationnel et containment 29
8.4 Notification et communication 30
8.5 Activation de la cellule de crise (en cas d'incident majeur) 30
8.6 Analyse post-incident et capitalisation 30
8.7 Plans d'action correctifs et préventifs 31
9. Tiers, prestataires et cloud 31
9.1 Politique de gestion des tiers 31
9.2 Contrôle des accès tiers 32
9.3 Revue des engagements de sécurité des tiers 32
9.4 Fournisseurs cloud : exigences de sécurité 33
9.5 Évaluation périodique des risques liés aux fournisseurs cloud 33
10. Conformité et audit 34
10.1 Revue annuelle de la politique SSI 34
10.2 Audits internes et contrôles périodiques 34
10.3 Suivi de la conformité réglementaire 35

10.4 Objectif de certification ISO/IEC 27001 35
10.5 Documentation et traçabilité des preuves 36
11 Politique d'usage acceptable - Charte informatique 36
12 indicateurs 37

1. Préambule

1.1 Objet de la politique

La présente politique de sécurité des systèmes d'information (SSI) constitue le cadre de référence en matière de sécurité de l'information de Logiclever. Elle précise les principes et les exigences fondamentales de sécurité qui s'appliquent au sein de Logiclever. Elle permet de garantir :

- La disponibilité des informations et des moyens de les traiter.
- L'intégrité des informations et des moyens de les traiter.
- La confidentialité des informations gérées.
- L'auditabilité et la traçabilité des moyens de traitement de l'information.

1.2 Domaine d'application

La présente politique est applicable à l'ensemble des directions de Logiclever. Elle couvre ainsi le périmètre du Système de Management de la Sécurité de l'Information (SMSI) de Logiclever.

Elle doit également être prise en compte par les partenaires, et ses principes fondamentaux s'appliquent aux prestations contractées par Logiclever.

La présente politique est indépendante des technologies. Elle garantit ainsi son applicabilité dans les différents contextes techniques.

En cas de non applicabilité d'une des règles de la présente politique, une procédure de dérogation doit être engagée et instruite par la Direction générale.

Aucune dérogation ne peut être accordée sans l'accord explicite du responsable de la

sécurité du système d'information (RSSI), actuellement Julien Bourlon.

1.3 Référentiels

La présente politique s'appuie sur des normes et cadres réglementaires reconnus afin de garantir un niveau de sécurité de l'information conforme aux exigences légales, contractuelles et industrielles. Elle prend principalement pour référence la norme **ISO/IEC 27001:2022**, qui définit les exigences pour la mise en œuvre d'un système de management de la sécurité de l'information (SMSI). Elle est également alignée sur les principes du **Règlement Général sur la Protection des Données (RGPD)** pour la protection des données à caractère personnel, applicables à toutes les activités de Logiclever. En complément, les guides de bonnes pratiques publiés par l'**Agence nationale de la sécurité des systèmes d'information (ANSSI)**, notamment ceux relatifs à la gestion de crise cyber, à l'hygiène numérique, et à la protection des données personnelles, servent de base opérationnelle à la définition des mesures de sécurité. Enfin, les exigences spécifiques de certains référentiels sectoriels ou contractuels (clauses client SSI, etc.) peuvent s'ajouter à ces fondations, et sont intégrées selon les besoins des projets concernés.

1.4 Engagement de la direction

La direction de Logiclever s'engage à faire respecter cette politique, à allouer les ressources nécessaires à sa mise en œuvre, et à promouvoir une culture de la sécurité.

1.5 Objectif de certification

Logiclever vise la certification ISO/IEC 27001 pour valider l'efficacité de son système de management de la sécurité de l'information.

2. Gouvernance et organisation SSI

La gouvernance de la sécurité de l'information chez Logiclever repose sur une organisation claire, des responsabilités définies, et des dispositifs de pilotage et de suivi structurés. Elle permet d'assurer la conformité, la réactivité et l'amélioration continue du niveau de sécurité dans l'entreprise.

2.1 Définition des rôles et responsabilités

Logiclever a défini précisément les responsabilités en matière de sécurité des systèmes d'information. Ces rôles sont attribués à différents profils (RSSI, DPO, responsables de

transfert, utilisateurs) et formalisés dans une **matrice des responsabilités**, annexée à la présente politique. Elle permet de clarifier :

- Qui est responsable de chaque domaine de sécurité ;
- Qui est consulté ou informé lors des actions de sécurité ;
- Qui pilote les activités stratégiques, opérationnelles ou de contrôle.

Cette répartition garantit la couverture de l'ensemble des obligations légales, réglementaires et organisationnelles. Elle est complétée par un suivi des actions récurrentes SSI.

2.2 Formalisation et diffusion de la politique SSI

La politique de sécurité des systèmes d'information est un document formel, approuvé par la direction de Logiclever. Elle définit les objectifs, principes, obligations et processus essentiels à la protection du patrimoine informationnel de l'entreprise.

Cette politique est :

- **Diffusée à l'ensemble des collaborateurs**, y compris freelances et sous-traitants ayant accès au SI ;
- **Intégrée au processus d'accueil** des nouveaux arrivants ;
- **Accessible en permanence** via les ressources internes partagées (intranet ou drive sécurisé).

2.3 Comité de pilotage de la sécurité

Un **comité de pilotage SSI** est organisé **au moins une fois par an**. Il réunit les acteurs clés de la sécurité (RSSI, DPO, RH, autres intervenants selon le besoin) afin de :

- Revoir l'évolution des risques et des menaces ;
- Évaluer l'efficacité des mesures en place ;
- Suivre les éventuelles actions et projets SSI en cours ou à lancer ;
- Préparer les audits internes ou externes.

Ce comité constitue un levier central de gouvernance et d'alignement stratégique de la SSI avec les besoins métiers.

2.4 Plan de traitement des risques

Logiclever dispose d'un **plan de traitement des risques** formalisé, qui s'appuie sur :

- L'identification des actifs critiques (applications, données, systèmes) ;
- L'évaluation des menaces, vulnérabilités et impacts associés ;
- La priorisation des risques selon leur criticité ;
- La définition de mesures correctrices ou préventives
- Le suivi dans le temps de l'état de traitement.

Le plan est mis à jour annuellement ou à la suite de changements significatifs dans l'environnement technique, réglementaire ou organisationnel.

2.5 Inventaire et classification des actifs

Un **inventaire des actifs informationnels** est maintenu à jour pour assurer une vision claire des éléments à protéger. Cet inventaire couvre :

- Les **données** (Confidentialité, Intégrité, Disponibilité, Criticité Globale) ; (ici)
- Les **applications** utilisées par les collaborateurs (SaaS uniquement) ; (ici)
- Les **supports physiques** (postes, disques, documents papier).

Chaque actif est classifié en fonction de sa **valeur, sensibilité et criticité** selon des critères de confidentialité, d'intégrité et de disponibilité. Cette classification permet d'ajuster les niveaux de protection, les accès autorisés et les mesures de sauvegarde ou de chiffrement.

3. Protection des données à caractère personnel

Logiclever s'engage pleinement à respecter le Règlement Général sur la Protection des Données (RGPD) ainsi que les bonnes pratiques relatives à la vie privée. La protection des données à caractère personnel fait partie intégrante de notre politique de sécurité des systèmes d'information et repose sur des processus structurés, des responsabilités claires et une sensibilisation adaptée.

3.1 Intégration du RGPD dans la politique SSI

La présente politique SSI intègre les obligations du RGPD en tant que cadre de référence pour tous les traitements de données personnelles qui pourraient être effectués par Logiclever. Elle précise les mesures techniques et organisationnelles alors mises en œuvre pour garantir un traitement conforme, éthique et sécurisé des données

à caractère personnel, qu'il s'agisse de données internes (employés, prestataires) ou externes (clients, partenaires).

3.2 Désignation du Délégué à la Protection des Données (DPO)

Logiclever a désigné un **Délégué à la Protection des Données (DPO)** en charge de :

- Superviser la conformité au RGPD ;
- Conseiller la direction et les équipes opérationnelles ;
- Répondre aux demandes des personnes concernées ;
- Être le point de contact avec l'autorité de contrôle (CNIL) ;
- Maintenir le registre des traitements.

Les coordonnées du DPO sont communiquées aux personnes concernées via les supports de communication internes et externes.

3.3 Principes de traitement des données personnelles

Il est interdit de mettre des données à caractère personnel sur le SI de Logiclever sauf quand cela est nécessaire pour le fonctionnement de Logiclever.

A date, seules les données RH (paie) sont collectées par Logiclever. Ces données sont gérées dans l'application de paye (Payfit) accessible par 4 personnes du support et les bulletins de paie sont mis à disposition des salariés dans un SAS privé où seuls eux et les 4 personnes du support ont accès.

Le cas échéant, tous les traitements de données à caractère personnel menés par Logiclever sont réalisés dans le respect des principes fondamentaux du RGPD, à savoir :

- **Finalité déterminée, explicite et légitime ;**
- **Minimisation** des données collectées au strict nécessaire ;
- **Exactitude** et mise à jour des données ;
- **Durée de conservation limitée**, selon la finalité et les obligations légales ;
- **Sécurité** appropriée (chiffrement, contrôle d'accès, auditabilité) ;
- **Transparence** vis-à-vis des personnes concernées.

Ces principes sont appliqués dès la conception des traitements et tout au long de leur cycle de vie.

3.4 Cartographie des traitements et responsabilités

Logiclever tient à jour une **cartographie complète des traitements** de données personnelles. Chaque traitement est documenté avec :

- Sa finalité ;
- Les catégories de données concernées ;
- Les destinataires ;
- Les durées de conservation ;
- Le responsable de traitement identifié (manager ou chef de service).

Cette documentation est revue au moins une fois par an ou en cas de modification significative d'un traitement.

3.5 Politique de minimisation des données

Une politique stricte de minimisation des données est en vigueur. Elle impose :

- De ne collecter que les données strictement nécessaires à une finalité définie ;=
- De ne pas conserver de données non utilisées ou périmées ;
- De limiter l'accès aux seules personnes autorisées et concernées.

Cette approche permet de réduire les risques liés à la conservation excessive ou inutile de données personnelles.

3.6 Exercice des droits des personnes

Logiclever garantit l'exercice effectif des droits des personnes concernées :

- **Droit d'accès** aux données les concernant ;
- **Droit de rectification** ;
- **Droit à l'effacement (droit à l'oubli)** ;
- **Droit à la portabilité** ;
- **Droit d'opposition**, dans les cas prévus.

Un **responsable de l'exercice des droits** est identifié (le DPO ou un membre désigné de son équipe), et les demandes sont traitées dans un délai maximal de 30 jours. Une adresse de contact prévue est mise à disposition à cet effet administratif@logiclever.com.

3.7 Procédure de notification en cas de violation

En cas de violation de données personnelles (perte, divulgation, accès non autorisé), Logiclever applique une procédure stricte de notification :

- **Identification et qualification** de l'incident par le RSSI et le DPO ;

- Notification à la **CNIL sous 72 heures**, si exigé ;
- Notification aux **personnes concernées** en cas de risque élevé pour leurs droits et libertés
- Documentation complète de l'incident, des mesures prises et des actions correctives.

Le DPO est le point de contact principal dans ce processus.

3.8 Formation et sensibilisation RGPD

Tous les collaborateurs de Logiclever sont **formés aux principes du RGPD et aux bonnes pratiques** de traitement des données personnelles. Cette montée en compétence est :

- Obligatoire dans l'année mois après l'intégration :
- Réactualisée régulièrement (au moins tous les deux ans) ;
- Adaptée aux besoins des différents postes
- Documentée (registre de formation conservé par le RSSI ou RH).

3.9 Effacement et suppression des données

Dans le cas ou des données personnelles sont enregistrées, Logiclever met en œuvre des **mécanismes d'effacement sécurisé** lorsque :

- Les durées de conservation sont atteintes ;
- La personne concernée exerce son droit à l'oubli ;
- Le traitement n'est plus nécessaire.

Les supports contenant des données supprimées (disques, fichiers, sauvegardés) font l'objet d'une **destruction conforme**, soit par effacement sécurisé logiciel, soit par destruction physique via des prestataires agréés.

4. Sécurité des utilisateurs et Ressources Humaines

La sécurité des systèmes d'information de Logiclever repose en grande partie sur les comportements des utilisateurs. C'est pourquoi des mesures spécifiques sont mises en place dès la phase de recrutement, tout au long du parcours collaborateur, et jusqu'à la fin de la relation contractuelle. Ces mesures sont adaptées selon les responsabilités et l'exposition aux risques des différents profils.

4.1 Vérification des antécédents professionnels

Pour les salariés, freelances et sous-traitants ayant accès au SI ou aux données sensibles, Logiclever applique une politique de **vérification des antécédents** lors du recrutement :

- Vérification des **diplômes** et de la formation déclarée ;
- **Appel de références professionnelles** (anciens employeurs, clients, responsables hiérarchiques) ;
- Requête via cabinets de recrutement spécialisés lorsque pertinent ;
- Contrôle d'identité et, si nécessaire, de casier judiciaire pour les postes à responsabilité.

4.2 Signature d'engagements de confidentialité

Tous les collaborateurs, internes ou externes, sont tenus de signer à leur arrivée :

- Un **accord de non-divulgation (NDA)** encadrant l'usage des informations confidentielles. Cette accord est inclus dans les contrats de travail pour les internes et dans les contrat de prestation pour les externes
- Une charte Charte informatique qui rappelle les valeurs, les responsabilités, les obligations en matière de sécurité, et les sanctions en cas de manquement.

Ces engagements sont également intégrés dans les contrats de prestation et contrat de travail, et réaffirmés lors de sensibilisations périodiques.

4.3 Attribution et révocation des accès

Les habilitations sont attribuées en fonction du profil de l'utilisateur. L'attribution des accès aux ressources informatiques repose sur le **principe du moindre privilège**. Le processus est le suivant :

- Chaque utilisateur dispose d'un **identifiant personnel unique** et non partageable.
- Création d'un compte utilisateur sur notre domaine (@logiclever.com)
- Attribution des droits selon un **profil d'accès prédéfini** (4 rôles).
- Accès limité dans le temps si besoin (ex. mission courte, prestataire) sachant que la désactivation de l'adresse "@logiclever.com" révoque de fait les accès au Drive et l'App_LL. Les consultants n'ayant pas accès aux autres applications avec des données sensibles.
- **Révocation systématique des accès** sous 24h en cas de départ ou de changement de rôle. Les RH mettent à jour sans délai l'annuaire en cas de mouvement d'un collaborateur.
- Revue **semestrielle des droits** par le RSSI

Toutes les opérations sont tracées et centralisées dans les applications où à lieu l'opération.

Le principe général en matière d'habilitation est le suivant : tout ce qui n'est pas expressément autorisé est interdit. La gestion globale des habilitations respecte le principe de séparation des fonctions (décision – mise en application – contrôle).

4.4 Sensibilisation et formation des utilisateurs

Chaque collaborateur bénéficie d'une **formation initiale à la sécurité** dès son intégration, suivie de **sensibilisations** adaptées à son rôle. Ces formations couvrent :

- Les fondamentaux de la cybersécurité (hameçonnage, ingénierie sociale, comportement à adopter) ;
- Les bonnes pratiques à mettre en place dans le cadre du BYOD
- Les principes de confidentialité et de gestion des données
- Les responsabilités spécifiques suivant le rôle
- Des cas pratiques et mises en situation.

Les actions sont suivies dans un **registre de formation**, contrôlé annuellement par le RSSI.

4.5 Politique de gestion des mots de passe

Il est prévue une **politique de mot de passe stricte** pour tous les systèmes qui seraient gérés par Logiclever :

- Longueur minimale de 12 caractères ;
- Complexité imposée (majuscule, minuscule, chiffre, caractère spécial) ;
- Interdiction des mots de passe déjà utilisés ou trop simples (liste noire) ;
- Renouvellement tous les 6 mois ;
- **Stockage chiffré de manière irréversible** (ex : bcrypt, PBKDF2) dans les bases ;
- Blocage du compte après 5 tentatives échouées.

Pour les services cloud utilisés par Logiclever :

- Les mots de passe dans les applications Logiclever sont générés automatiquement et doivent être changés à la première connexion.
- Nous utilisons les règles de gestion des mots de passe de nos fournisseurs qui sont tous certifiés
- Toutes les applications utilisées par Logiclever permettent d'avoir des mots de passe stockés à l'aide d'un chiffrement irréversible

L’usage de gestionnaires de mots de passe est recommandé.

4.6 Authentification forte (MFA)

Nous prévoyons l’obligation de L’**authentification multifacteur (MFA)** dans les cas suivants :

- Accès à distance (VPN, cloud, backoffice) ;
- Sur les applications critiques (Payfit)
- Utilisation de **comptes à privilèges** (administrateurs, RSSI, RH).

Les méthodes acceptées incluent : application d’authentification (OTP), clé physique, token ou SMS sécurisé. Les journaux de connexions MFA seraient conservés pour analyse post-incident.

4.7 Politique BYOD (Bring Your Own Device)

Logiclever autorise l’usage de matériel personnel (ordinateurs, smartphones) dans un cadre strictement défini par une **politique BYOD formalisée**, communiquée via un **guide de bonnes pratiques**. Cette politique impose :

- L’utilisation du matériel fourni par le client pour les travaux réalisés dans le cadre d’une mission.
- Des prérequis techniques : OS à jour, antivirus actif, chiffrement du disque ;
- L’usage de mots de passe forts et le **verrouillage automatique** des appareils en l’absence de l’utilisateur ;
- L’interdiction de stocker localement des données sensibles ;
- L’activation de fonctions de **localisation et d’effacement à distance** ;
- La séparation des usages pro/perso (comptes, navigateurs, applications) ;
- Une vigilance particulière sur les connexions Wi-Fi et l’environnement de travail.

Le guide BYOD est signé par tout utilisateur concerné, et mis à jour annuellement.

5. Sécurité des systèmes d’information

La sécurité technique et opérationnelle des systèmes d’information est un pilier central de la politique SSI de Logiclever. Elle vise à garantir la confidentialité, l’intégrité, la disponibilité et la traçabilité des informations manipulées dans l’environnement numérique de l’entreprise.

5.1 Chiffrement des données au repos et en transit

Toutes les données sensibles traitées par Logiclever, en particulier les données personnelles et confidentielles, sont protégées par des **mécanismes de chiffrement robustes**, en conformité avec les exigences réglementaires et les bonnes pratiques sectorielles :

- **Chiffrement au repos** (at rest) appliqué aux disques, bases de données et fichiers via des algorithmes éprouvés (ex : AES-256) sur les services cloud utilisés.
- **Chiffrement en transit** (in transit) pour tous les échanges via des protocoles sécurisés (TLS 1.2 ou supérieur, HTTPS, SFTP).
- Les solutions SaaS (Google Workspace, Payfit, BoondManager) utilisées par Logiclever assurent nativement ces protections.

5.2 Cloisonnement des réseaux et filtrage des flux

- Sans objet, Logiclever n'ayant pas de réseau

5.3 Isolation des données clients

Les données appartenant aux clients ne sont **pas intégrées dans le SI de Logiclever**, mais traitées dans des environnements sécurisés fournis par ces mêmes clients (infrastructures dédiées). Cela garantit :

- L'**isolation logique et physique** des données externes ;
- L'absence de co-traitement ou d'hébergement non autorisé ;
- La réduction des risques de divulgation ou d'accès accidentel par des tiers.

5.4 Gestion et destruction des supports physiques

Logiclever applique une politique rigoureuse de gestion des supports physiques :

- Logiclever est d'abord une **entreprise Zéro Papier**, nous n'imprimons ni ne gérons aucun document papier pour notre fonctionnement
- Les **documents sensibles éventuels** sont numérisés, puis **détruits via une déchiqueteuse certifiée** ou confiés à un prestataire spécialisé.
- Les **supports numériques (disques durs, clés USB, ordinateurs)** sont chiffrés et leur accès est restreint aux personnes autorisées.
- En fin de cycle de vie, les supports sont **effacés de manière sécurisée** (logiciel d'effacement certifié ou destruction physique).

5.6 Sauvegardes et archivage

Le **RSSI** veille à ce que nos fournisseurs (SAAS) respectent une politique de sauvegarde rigoureuse :

- Sauvegardes **quotidiennes automatiques** des documents internes sur Google Drive avec versioning activé.
- Conservation des copies pendant **30 à 90 jours** selon la typologie.
- Stockage des sauvegardes sur des **espaces chiffrés et redondants** dans l'UE.
- **Test de restauration** réalisé au moins deux fois par an.
- Suppression des sauvegardes périmées selon une **politique d'effacement planifiée**, validée par le DPO si des données personnelles sont concernées.

5.7 Continuité des opérations

Logiclever adopte une approche proactive de la continuité des opérations :

- Un **plan de continuité technique** repose sur les fonctionnalités cloud de haute disponibilité (Google Cloud, SaaS résilients).
- Des **solutions de repli** sont définies pour les utilisateurs en cas de panne majeure (accès aux supports en local, duplication temporaire).
- Un plan organisationnel est activable en cas de **cyberattaque, perte d'accès ou incident matériel**, intégrant les rôles de chacun (RSSI, DPO, Direction).
- Des exercices ponctuels de simulation (type "table-top") sont prévus pour tester la réactivité des équipes.

5.8 Politique de gestion des vulnérabilités

Un **plan de gestion des vulnérabilités** est formalisé afin de prévenir l'exploitation de failles logicielles :

- Veille sur les vulnérabilités critiques (bases CVE, bulletins éditeurs) par le RSSI.
- Scan automatique intégrés à Google Workspace Admin
- Classification des vulnérabilités selon ce tableau :

Criticité	Exemple	Délai cible de correction
Critique	accès non autorisé à des données, RCE, faille 0-day exploitée	< 48h
Élevée	possibilité d'escalade de privilèges ou contournement d'accès	< 7 jours
Moyenne	défaut de configuration,	< 30 jours

	version obsolète sans POC public	
Faible	alerte informative, ne nécessitant pas d'action immédiate	Ajouté dans le backlog RSSI, traitement au cas par cas

- Application rapide des **correctifs de sécurité (patchs)** dès leur disponibilité, en priorité sur les composants critiques
- Revue des vulnérabilités affectant les services cloud (via les portails de sécurité des éditeurs).
- Réalisation de test de pénétration et d'audits de sécurité sur notre infrastructure conduite par le RSSI et réaliser de manière aléatoire sur tous les points de sécurité de Logiclever
- Journalisation des actions correctives
- Tout correctif impliquant un changement système (ex. : mise à jour, modification configuration) est géré via le processus de **gestion des changements**

5.9 Politique de gestion des correctifs de sécurité (patchs)

Logiclever applique une **politique rigoureuse de gestion des correctifs de sécurité** visant à maintenir l'ensemble de son environnement technique à jour face aux vulnérabilités connues.

- Les postes de travail, équipements BYOD autorisés et services cloud sont soumis à une **veille sécurité** régulière effectuée par le **RSSI** via des sources officielles (CVE, CERT-FR, éditeurs).
- Les mises à jour critiques et de sécurité sont **appliquées dès leur publication** pour les services cloud, et **dans un délai maximal de 7 jours** pour les postes internes ou équipements sous responsabilité Logiclever.
- Pour les applications SaaS utilisées, Logiclever s'assure contractuellement que les correctifs de sécurité sont intégrés par les fournisseurs selon un processus formalisé, vérifié lors des revues annuelles.

Les utilisateurs sont sensibilisés à **ne pas différer les mises à jour système**, en particulier dans le cadre de la politique BYOD. Les incidents dus à des correctifs non appliqués sont analysés dans le cadre du plan de gestion des vulnérabilités.

5.10 Identification et retrait des systèmes obsolètes et Shadow IT

Dans le cadre de la prévention des risques liés à l'obsolescence technologique, Logiclever met en œuvre un processus de **détection et de retrait des systèmes ou applications non maintenus** (legacy) ou non autorisés (Shadow IT).

- Une **revue des applications utilisées** est effectuée tous les six mois dans le cadre de l'inventaire des actifs applicatifs.
- Tout outil, script ou service cloud non validé par la DSI ou le RSSI est **considéré comme Shadow IT** et doit être signalé, évalué, puis supprimé ou régularisé.
- Les **versions logicielles installées sur les postes internes** ou BYOD sont vérifiées à l'aide de contrôles manuels ou automatisés. Les versions non supportées (fin de support éditeur) sont interdites et font l'objet d'un plan de migration ou de retrait.

La politique de sécurité interdit l'usage d'outils non référencés ou à usage personnel dans un cadre professionnel, sauf autorisation explicite du RSSI. Toute dérogation temporaire doit être documentée et justifiée.

Ce contrôle contribue à **réduire la surface d'exposition aux vulnérabilités** et à garantir que seules des applications maîtrisées, maintenues et conformes aux exigences de sécurité sont utilisées dans l'environnement Logiclever.

6. Sécurité dans les projets et développements

Même si Logiclever n'a pas pour activité le développement applicatif interne, l'entreprise prévoit, dans une logique de prévention et de conformité, l'intégration systématique de la sécurité dans la conduite de projets. Cette approche concerne aussi bien les projets internes (mise en place d'un nouvel outil, d'un service ou d'un processus métier) que les projets à composante logicielle. Elle s'appuie sur les exigences de la norme **ISO/IEC 27001:2022 – Clause 5.8**.

6.1 Intégration de la sécurité dès le cadrage projet

Pour tout nouveau projet technique ou organisationnel, Logiclever prévoit une **évaluation initiale des besoins de sécurité** dès la phase de cadrage. Cela inclut :

- L'identification des **données sensibles ou personnelles** qui pourraient être traitées ;

- L'analyse des **risques potentiels** (interruption de service, non-conformité, faille) ;
- La définition des **exigences de sécurité** à respecter (chiffrement, auditabilité, gestion des accès, résilience) ;
- La documentation des mesures de protection à intégrer au cycle projet.

Cette analyse est pilotée par le chef de projet, avec l'appui du **RSSI** et, si nécessaire, du **DPO**.

6.2 Intégration de la sécurité dans le cycle de vie projet

Logiclever applique une **démarche sécurité by design** tout au long du cycle de vie de ses projets. Cette démarche comprend :

- L'évaluation des exigences SSI dans les **spécifications fonctionnelles** ;
- La **validation sécurité des choix techniques** (hébergement, interconnexion, gestion des comptes) ;
- La mise en place de **revues de sécurité** aux jalons clés du projet ;
- La documentation continue des éléments de sécurité (traçabilité, journalisation, classification des données, procédures en cas d'incident).

Tout projet ayant un impact sur les systèmes critiques est soumis à **validation du RSSI avant mise en production**.

6.3 Développement sécurisé (le cas échéant)

Dans l'éventualité où Logiclever mènerait des projets de développement logiciel interne ou en sous-traitance, la société a défini une **méthodologie de développement sécurisé**, reposant sur les bonnes pratiques suivantes :

- Respect des recommandations de l'**OWASP** pour les applications Web ;
- Utilisation d'**outils d'analyse statique** du code source pour détecter les vulnérabilités (SAST) ;
- Application de **tests dynamiques** de sécurité avant mise en production (DAST) ;
- Utilisation de bibliothèques tierces maintenues, vérifiées et sans vulnérabilités connues (suivi CVE) ;
- Documentation des fonctions critiques (authentification, gestion des droits, traçabilité).

6.4 Formation des équipes projets

Les chefs de projet, responsables de traitement, contributeurs techniques et, le cas échéant, les développeurs internes ou sous-traitants sont **formés aux principes de sécurité applicative**. Les formations portent sur :

- Les risques liés aux erreurs de développement (injection, XSS, CSRF, etc.) ;
- L'approche sécurité dans les projets SaaS ou cloud ;
- Les obligations réglementaires (RGPD, traçabilité, droits des personnes) ;
- L'interopérabilité sécurisée entre systèmes (API, interconnexions).

Ces formations peuvent s'appuyer sur des ressources internes ou des formations externes certifiantes.

6.5 Tests de sécurité avant mise en production

Avant toute mise en production d'une nouvelle solution (application, outil, processus numérique), Logiclever prévoit des **vérifications sécurité formalisées**, comprenant :

- Des **tests fonctionnels** couvrant les cas d'usage critiques pour la sécurité (authentification, création de compte, export de données) ;
- Des **tests de résistance aux erreurs** (cas limites, injection de données invalides)
- La **vérification du cloisonnement des données**, des logs, et des journaux d'audit ;
- La revue des droits et du comportement en cas de session expirée, d'erreur ou d'accès non autorisé.

Aucun projet critique ne peut être mis en service sans validation du RSSI sur ces aspects.

7. Exploitation et infrastructures

La maîtrise des environnements techniques et de leur exploitation au quotidien est essentielle pour assurer la sécurité des systèmes d'information. Logiclever s'assure que ses fournisseurs de solution SAAS mettent en œuvre des processus rigoureux pour garantir la stabilité, la résilience et la conformité de leur infrastructure informatique, notamment sur les aspects liés aux changements, à la capacité, à la messagerie, aux accès physiques et à l'environnement cloud.

7.1 Gestion des changements

Logiclever a formalisé un **processus de gestion des changements (Change Management)** s'appliquant à l'ensemble des actifs SSI (applications, systèmes, configurations réseau, processus organisationnels).

1. **Soumission des changements**

- Toute demande de changement doit être consignée dans un registre (ticketing ou formulaire validé).
- Le demandeur doit préciser la nature du changement, l'actif concerné, les justifications, et les impacts attendus.

2. **Évaluation des impacts de sécurité**

- Un **security assessment** est réalisé par le RSSI (ou par un expert désigné) afin d'évaluer les impacts du changement sur la confidentialité, l'intégrité et la disponibilité du SI.
- En cas d'impact significatif, des mesures compensatoires doivent être définies avant mise en œuvre.

3. **Approbation préalable**

- Aucun changement ne peut être implémenté sans une **validation formelle** :
    - Changements mineurs : validation par le manager concerné,
    - Changements majeurs : validation par le comité SSI ou la direction.

4. **Mise en œuvre et documentation**

- Chaque changement est documenté (date, responsables, actions menées, résultat).
- Un plan de retour arrière (rollback) est prévu pour les changements critiques.

5. **Suivi et revue**

- Des revues régulières du registre des changements sont effectuées par le RSSI pour s'assurer de la traçabilité et de la conformité.

7.2 Plan de gestion de la capacité

Les **plans de gestion de capacité** sont inclus dans les prestations SAAS de nos fournisseurs. Leur mise en place garantit la performance des systèmes et anticipe les saturations ou indisponibilités. Ces plans incluent :

- La **surveillance continue** de l'utilisation des ressources sur les environnements critiques;
- L'utilisation de **seuils d'alerte** paramétrés (ex. : alerte à 80 % de charge) pour déclencher des actions proactives ;
- Des **revues annuelle de la capacité** pour planifier les extensions ou adaptations nécessaires ;
- Une **prévision de charge** lors de l'introduction de nouvelles applications ou de nouveaux utilisateurs.

Ces données alimentent la planification budgétaire et le dimensionnement de l'infrastructure.

7.3 Protection de la messagerie électronique

La messagerie est un vecteur de menace critique. Logiclever a défini une **politique de protection des emails** comportant les éléments suivants :

- **Filtrage anti-spam** et anti-malware configuré sur tous les serveurs de messagerie ;
- **Scan automatique des pièces jointes** et des liens (analyse comportementale si possible) ;
- **Blocage des extensions à risque** (ex. : .exe, .js, .vbs) ;
- **Authentification du domaine d'envoi** via les protocoles SPF, DKIM et DMARC ;
- **Formation des utilisateurs** sur la détection des emails frauduleux (phishing, spear-phishing, usurpation d'identité).
- Nous n'échangeons aucune donnée sensible par mail

Des alertes sont générées pour les tentatives d'usurpation de domaine ou les anomalies comportementales (envois massifs, connexions suspectes).

7.4 Contrôle des accès physiques

Logiclever met en œuvre des mesures pour **protéger physiquement les équipements critiques** (matériel informatique, documents papier sensibles) :

- Les locaux contenant des équipements informatiques sont **verrouillés** en dehors des heures de présence.
- L'accès à ces zones est **réservé aux personnes autorisées**, sur badge, clé ou contrôle manuel.
- Une **revue des droits d'accès physiques** est réalisée annuellement par les RH en coordination avec les responsables de site.

- **La révocation des accès physiques** est déclenchée automatiquement lors de la sortie d'un collaborateur.

Les matériels sensibles (disques, PC, disques durs externes) doivent être **stockés en lieux sécurisés**, avec chaîne de responsabilité identifiée.

7.5 Journalisation des activités des utilisateurs

Logiclever enregistre les **traces d'activité des utilisateurs** accédant à ses systèmes d'information, qu'il s'agisse de collaborateurs internes, de prestataires ou de freelances.

Ces enregistrements comprennent notamment :

- L'identifiant de l'utilisateur,
- La date et l'heure de connexion,
- Les actions critiques réalisées (création, modification, suppression, export de données),
- L'adresse IP ou l'environnement de connexion (si disponible).

Les traces sont activées sur les solutions SaaS utilisées par Logiclever conformément aux capacités de journalisation fournies par ces prestataires.

7.6 Journalisation des activités sur les applications

Les **journaux d'activité des applications cloud** sont configurés de manière à :

- Retracer les opérations sensibles (accès à des fichiers, changement de permissions, export de données) ;
- Permettre l'identification d'une action ou d'un incident ultérieur ;
- Être exploités en cas d'enquête de sécurité, d'audit ou de demande réglementaire (ex. RGPD).

Des journaux sont activés dans :

- **Google Workspace** via le centre de sécurité et les rapports d'activité d'administration ;
- **Payfit** via l'historique RH des actions effectuées sur les fiches de paie et profils ;
- **BoondManager** pour le suivi des exports, des modifications de fiche consultant, client ou mission ;

7.7 Protection et intégrité des journaux

Les journaux d'activité font l'objet de **mesures de protection** contre :

- La **modification ou suppression non autorisée** ;
- L'**accès injustifié** à des enregistrements sensibles.

Les accès aux journaux sont :

- **Réservés aux administrateurs** ou personnes habilitées par le RSSI ;
- **Traçables et contrôlés** périodiquement dans le cadre du plan d'audit SSI.

Les journaux sont **conservés pour une durée de 6 mois minimum**, sauf exigence spécifique, et sont **stockés dans un environnement sécurisé** ou dans les solutions cloud utilisées.

7.8 Sécurité du réseau

De manière préventive, dans le cas où Logiclever mettrait en place un réseau, voici les mesures de sécurité pour garantir l'intégrité, la confidentialité et la disponibilité de son réseau interne et des connexions de ses utilisateurs.

1. Cloisonnement du réseau (Network Segregation)

- Le réseau est segmenté en zones logiques distinctes (administration, utilisateurs, invités, prestataires).
- Les flux interzones sont filtrés et surveillés

2. Administration sécurisée (Network Administration Security)

- Les accès administrateurs aux équipements réseau sont limités aux personnes habilitées.
- L'authentification forte (MFA) est obligatoire pour les accès d'administration.
- Toutes les actions d'administration sont journalisées
- Les accès administrateur sont supprimés en cas de départ ou d'inactivité

3. Sécurité périmétrique (Perimeter Layer Security)

- Les flux entrants et sortants sont contrôlés par des pare-feu et des systèmes de

filtrage.
- Une politique de blocage par défaut est appliquée : seuls les flux autorisés explicitement sont ouverts.
- Les connexions suspectes ou non conformes sont automatiquement bloquées et remontées au RSSI.

4. Sécurité du Wi-Fi (Wireless Security)

- Les réseaux Wi-Fi internes utilisent le protocole WPA3 ou, à défaut, WPA2-Enterprise avec authentification forte.
- Les réseaux invités sont isolés du réseau de production et cloisonnés par VLAN.
- Les clés de chiffrement Wi-Fi sont renouvelées régulièrement.

7.9 Sécurité des postes de travail

Cette section complète notre politique BYOD, afin de garantir la sécurité des postes de travail utilisés par les collaborateurs, Logiclever impose des mesures de sécurités aux employées

Sur les **solutions de protection des terminaux (EPP)**.

- Tous les postes de travail (Windows 10) doivent disposer au minimum d'une solution de protection intégrée (**Microsoft Defender** ou équivalent).
- Les utilisateurs sont encouragés à renforcer cette protection avec un antivirus/antimalware approuvé par le RSSI en cas d'usage professionnel intensif. Cet protection doit inclure :
    - Protection en temps réel contre les logiciels malveillants.
    - Détection automatique des menaces et alertes.
    - Mise à jour automatique de la base de signatures.

Sur le Verrouillage automatique des postes de travail :

- Tous les postes de travail sont configurés pour se verrouiller automatiquement après **5 minutes d'inactivité**.
- Le verrouillage est obligatoire en cas de départ de poste, même de courte durée.

Le RSSI peut vérifier ces points lors des audits internes de sécurité et à l'arrivée du

collaborateur.

7.10 Surveillance et détection des comportements anormaux

L'activité des utilisateurs et des systèmes est **surveillée régulièrement**, afin de :

- Détecter toute tentative d'accès non autorisé ou usage anormal ;
- Identifier des comportements suspects (vol de données, accès massifs, anomalies horaires) ;
- Réagir rapidement en cas d'incident, en lien avec le processus de gestion des incidents.

Cette surveillance s'appuie :

- Sur les capacités de détection natives des outils cloud ;
- Sur la veille du RSSI ;
- Et sur les retours des utilisateurs, sensibilisés à signaler les comportements inhabituels.

7.11 Sécurité des supports de stockage amovibles

Afin de prévenir toute fuite ou compromission de données en cas de perte ou de vol, Logiclever applique une politique stricte en matière d'utilisation des **supports de stockage amovibles** (clés USB, disques durs externes, cartes SD, etc.) :

- Tous les supports amovibles utilisés dans le cadre des activités professionnelles de Logiclever doivent être **chiffrés** à l'aide d'algorithmes conformes à l'état de l'art (AES-256 ou équivalent). Le chiffrement est assuré soit via des solutions natives, soit par des outils validés par le RSSI.
- L'usage de supports amovibles est limité aux situations strictement nécessaires (ex. transferts sécurisés vers un client ne permettant pas l'accès cloud).
- Le RSSI réalise périodiquement un contrôle de conformité sur les supports utilisés.
- Les supports non chiffrés ou personnels sont interdits pour le transfert de données professionnelles.
- Les supports doivent être conservés dans un lieu sécurisé lorsqu'ils ne sont pas utilisés (armoire fermée, bureau sécurisé).
- En cas de déplacement, ils doivent être transportés avec les mêmes précautions qu'un ordinateur portable.

- Toute perte, vol ou incident lié à un support amovible doit être immédiatement signalé au RSSI et au DPO afin d'évaluer l'impact potentiel et, le cas échéant, notifier la CNIL et les personnes concernées (cf. procédure de gestion des incidents, section 8).

7.11 Règles de gestion des clés de chiffrement

Logiclever a mis en place une politique formalisée de gestion des clés de chiffrement, garantissant la protection des informations tout au long de leur cycle de vie.

Les règles appliquées sont les suivantes :

- Les clés de chiffrement sont générées à l'aide d'algorithmes reconnus comme robustes par les standards internationaux (AES-256, RSA-2048 ou supérieur, TLS 1.3).
- La génération est réalisée via les mécanismes intégrés aux solutions cloud utilisées (Google Workspace, Payfit, BoondManager, etc.) ou par des outils validés par le RSSI.
- Chaque clé possède une durée de vie limitée et fait l'objet d'une **rotation périodique** selon les recommandations du fournisseur ou, à défaut, tous les 12 mois.
- Les clés compromises ou suspectées de l'être sont immédiatement révoquées et remplacées.
- Seules les personnes habilitées (RSSI, administrateurs systèmes désignés) peuvent gérer les clés.
- Les opérations de gestion (création, modification, révocation) sont journalisées et vérifiées.
- Les clés obsolètes ou remplacées sont détruites de manière sécurisée, conformément aux bonnes pratiques de l'ANSSI et aux standards ISO.

7.12 Stockage séparé des clés de chiffrement

Afin de limiter les risques d'accès non autorisé aux données, Logiclever impose que les clés de chiffrement soient **stockées séparément des données chiffrées**.

- Dans les environnements cloud utilisés (Google, Payfit, BoondManager, Slack, Pennylane, Amundi, Henner), les clés de chiffrement sont gérées via

des **modules matériels de sécurité (HSM)** ou services dédiés (Cloud KMS), indépendants des systèmes de stockage.
    - La gestion des clés est confiée à des services sécurisés distincts de ceux hébergeant les données.
    - Les administrateurs n'ont pas simultanément accès aux données chiffrées et aux clés.
    - L'accès aux clés est soumis à une **authentification forte (MFA)** et à une gestion stricte des habilitations.
    - Les journaux d'accès aux clés sont conservés et surveillés par le RSSI.
    - Cette séparation est exigée par la politique SSI de Logiclever afin de se conformer au RGPD et aux standards de sécurité internationaux (ISO 27001, ISO 27018, SOC 2).
    - Les clés de chiffrement

7.13 Politique de bureau propre (Clean Desk Policy)

Afin de limiter les risques de fuite d'information, de perte de documents ou de vol de matériel, Logiclever applique une politique stricte de **bureau propre (Clean Desk Policy)**, applicable à l'ensemble des collaborateurs, prestataires et freelances, dans les locaux de l'entreprise comme dans tout environnement de travail en clientèle ou en télétravail.

- Tous les **documents contenant des données professionnelles** (contrats, factures, dossiers RH, notes internes) doivent être rangés dans des armoires ou tiroirs **fermés à clé** lorsqu'ils ne sont pas utilisés.
- Les documents temporaires ou obsolètes doivent être **détruits** par une méthode sécurisée (déchiqueteuse ou prestataire agréé).
- Il est interdit de laisser sur le bureau des informations sensibles visibles (post-it avec mots de passe, impressions non collectées, dossiers ouverts).
- Les ordinateurs portables et équipements mobiles doivent être **verrouillés** en cas d'absence, même de courte durée.
- En fin de journée, les ordinateurs portables doivent être **rangés dans un lieu sécurisé** (casier, armoire fermée).
- Les supports amovibles (clés USB, disques durs externes) doivent être **chiffrés** et rangés lorsqu'ils ne sont pas utilisés (cf. politique sur les supports amovibles). Les postes doivent être configurés pour un **verrouillage automatique** après 5 minutes d'inactivité.
- Il est interdit de noter ou afficher des **mots de passe visibles** dans les environnements de travail.
- Les collaborateurs doivent signaler immédiatement au RSSI toute **perte ou vol de matériel** (ordinateur, badge, périphérique).

- La Clean Desk Policy s'applique également en **télétravail** ou lors de missions chez des clients.
- Les documents professionnels ne doivent pas être laissés visibles dans des espaces partagés (coworking, domicile accessible à des tiers).
- En mobilité, les ordinateurs et supports physiques doivent rester **sous la surveillance directe du collaborateur**.
- Des **contrôles périodiques** peuvent être effectués par le RSSI ou les managers pour vérifier son application.

7.14 Suppression sécurisée des fichiers et supports

Afin d'éviter toute fuite d'information lors de la mise au rebut ou du recyclage d'un support de stockage, Logiclever applique une politique de **suppression sécurisée** :

1. Effacement logiciel sécurisé

- Les fichiers sensibles doivent être supprimés à l'aide d'outils de suppression sécurisée validés par le RSSI (écrasement multiple des données).
- Cette opération est réalisée par l'utilisateur ou, pour les supports complets, par le RSSI.

2. Destruction physique

- Les disques durs et supports amovibles obsolètes sont confiés à un **prestataire agréé** pour destruction physique.
- Un certificat de destruction peut être exigé pour preuve de conformité.

7.15 Conformité réglementaire des transferts de données

Logiclever veille à ce que tout transfert de données, qu'il s'agisse de données internes ou de données personnelles, soit réalisé en conformité avec les **réglementations locales et internationales applicables**.

- Tout transfert de données personnelles doit respecter le **Règlement Général sur la Protection des Données (RGPD)** pour les données collectées et traitées dans l'Union Européenne.
- En cas de transfert hors UE, Logiclever s'assure que le pays destinataire bénéficie d'une **décision d'adéquation** de la Commission Européenne, ou que des garanties appropriées sont mises en place (Clauses Contractuelles Types – SCCs, accords de sous-traitance conformes).

- Le **DPO** est responsable de vérifier la conformité des transferts avec les lois applicables. Le **RSSI** s'assure que les moyens techniques de chiffrement et de sécurisation sont appliqués lors du transfert.
- Les transferts doivent être documentés dans le **registre des traitements** (article 30 RGPD)
- Des audits périodiques peuvent être menés afin de vérifier la conformité contractuelle des fournisseurs cloud (Google Workspace, Payfit, BoondManager, Slack, Pennylane, Amundi, Henner).
- Tous les transferts de données s'effectuent via des **protocoles sécurisés** (TLS 1.2 ou supérieur).
- Les données sensibles doivent être chiffrées avant transfert (AES-256 ou équivalent).

8. Gestion des incidents de sécurité

Logiclever adopte une approche structurée pour la gestion des incidents de sécurité de l'information afin de limiter leur impact, d'assurer une réponse rapide et proportionnée, et de tirer parti de chaque incident pour améliorer son dispositif global de sécurité. Cette politique s'aligne sur les exigences de l'ISO/IEC 27001:2022 et sur les bonnes pratiques de gestion de crise recommandées par l'ANSSI.

8.1 Détection et signalement des incidents

Tout collaborateur, prestataire ou utilisateur disposant d'un accès au SI de Logiclever est **tenu de signaler sans délai** tout incident ou comportement anormal suspecté, tel que :

- Perte ou vol de matériel contenant des données ;
- Tentative de phishing ou compromission de compte ;
- Comportement anormal d'un système (ralentissement, pop-up, connexions inhabituelles) ;
- Erreur humaine ayant causé une exposition de données.

Les signalements peuvent être faits par :

- Email à l'adresse prévue sécurisé **administratif@logiclever.com**
- Appel direct au RSSI

Tous les utilisateurs sont sensibilisés à cette obligation et formés à reconnaître les situations à risque.

8.2 Qualification et journalisation des incidents

Dès qu'un incident est signalé, il est **enregistré dans un registre des incidents** tenu par le RSSI. Ce registre contient :

- La date et l'heure du signalement ;
- L'identifiant du déclarant ;
- La nature supposée de l'incident ;
- Le périmètre affecté ;
- La gravité estimée (selon un barème interne) ;
- L'impact potentiel sur les données, les utilisateurs, les clients ou la disponibilité.

Le RSSI ou une personne désignée effectue une **qualification de l'incident** dans un délai court (généralement < 4 heures ouvrées) afin de déterminer s'il s'agit d'un événement bénin, d'un incident de sécurité ou d'un incident majeur.

8.3 Traitement opérationnel et containment

Une fois qualifié, l'incident fait l'objet de **mesures immédiates de contention et de traitement**, pouvant inclure :

- L'**isolement du système concerné** (poste, réseau, cloud) ;
- Le **blocage d'un compte compromis** ;
- Le **retrait temporaire d'un accès à privilège** ;
- L'**analyse antivirus ou forensic rapide** ;
- Le **renforcement de filtrages** ou de règles de détection.

L'objectif est de **limiter l'impact**, d'éviter la propagation et de **préserver les preuves** si

une analyse approfondie est nécessaire.

8.4 Notification et communication

Lorsque l'incident implique des **données personnelles**, des **données sensibles**, ou un **client affecté**, des actions de notification sont déclenchées selon un protocole défini :

- Notification à la **CNIL dans un délai de 72 heures** par le DPO si nécessaire (conformément au RGPD) ;
- **Information aux personnes concernées** (internes ou externes) si un risque élevé pour leurs droits est identifié ;
- **Information aux clients** concernés par une compromission de service, de données ou d'image ;
- Communication interne coordonnée avec la direction pour éviter la diffusion d'informations erronées.

Les modèles de notification sont prêts à l'emploi et revus.

8.5 Activation de la cellule de crise (en cas d'incident majeur)

Dans le cas d'un **incident majeur** (ransomware, interruption massive de services, exfiltration de données critiques, etc.), une **cellule de crise SSI** est activée. Elle est composée de :

- Le RSSI (coordinateur) ;
- Le DPO (si données personnelles concernées) ;
- L'équipe de communication si impact externe.

La cellule de crise suit un **plan d'action structuré** : évaluation → containment → communication → retour à la normale → post-mortem.

8.6 Analyse post-incident et capitalisation

Après tout incident de sécurité, une **revue post-incident (retour d'expérience)** est réalisée par le RSSI avec les parties impliquées, incluant :

- L'analyse de la cause racine ;
- Le déroulé des événements et la chronologie ;
- Les mesures correctives mises en œuvre ;
- Les leçons apprises ;

- Les recommandations d'amélioration.

Cette analyse est formalisée dans un **rapport d'incident** et, selon les cas, présentée au comité SSI.

8.7 Plans d'action correctifs et préventifs

En fonction de la nature et de la gravité de l'incident, des **plans d'action sont définis** pour corriger les vulnérabilités découvertes et éviter les récurrences. Ces actions peuvent inclure :

- La mise à jour ou le durcissement de systèmes ou de procédures ;
- Le renforcement des formations et sensibilisations ;
- L'ajustement de droits d'accès ou de configurations techniques ;
- L'acquisition ou l'activation de protections supplémentaires (MFA, EDR, audit de code…).

Les actions sont suivies dans un plan dédié, avec responsable, échéance et statut, sous le contrôle du RSSI.

9. Tiers, prestataires et cloud

Logiclever s'appuie sur un écosystème de partenaires, fournisseurs de services et solutions cloud pour la conduite de ses activités. Pour préserver la sécurité de l'information et maîtriser les risques liés à l'externalisation, l'entreprise a mis en place une politique rigoureuse de gestion des tiers, fondée sur le principe de responsabilité partagée, de traçabilité et d'évaluation continue.

9.1 Politique de gestion des tiers

Toute relation contractuelle avec un tiers (prestataire, sous-traitant, freelance, fournisseur SaaS) fait l'objet de **clauses de sécurité spécifiques**, négociées dès la contractualisation. Ces clauses incluent :

- **Un engagement de confidentialité (NDA)** ;
- **Respect des politiques SSI de Logiclever** (cf. Contrat sous-traitance)
- Interdiction d'**externaliser à leur tour des ressources ou des sous-traitants** sans accord formel (cf. Contrat sous-traitance)
- Définition claire de la nature des accès, des données concernées et des

responsabilités de chacun ;
- **Engagements en matière de notification d'incidents, de conformité réglementaire (RGPD) et de destruction des données en fin de contrat.**

Les contrats sont systématiquement validés par le RSSI et/ou le DPO selon les cas.

9.2 Contrôle des accès tiers

Les tiers ne peuvent accéder au système d'information de Logiclever que dans les conditions suivantes :

- **Accès strictement limité** aux ressources nécessaires à la mission ;
- **Création d'un compte dédié** (identifiant unique, traçable) avec date d'expiration automatique ;
- **Journalisation des connexions** et des actions réalisées ;
- Utilisation obligatoire d'une **authentification forte (MFA)** pour les accès à distance ou à privilèges ;
- **Surveillance en temps réel** des sessions sensibles (administration, intégration API…).

Tout accès non utilisé depuis 30 jours est automatiquement désactivé.

9.3 Revue des engagements de sécurité des tiers

Les engagements des fournisseurs et prestataires font l'objet d'une **revue annuelle ou à l'issue de tout incident**, afin de :

- Vérifier le **maintien des niveaux de service et de sécurité** ;
- Contrôler la **mise à jour des certifications** (ISO 27001, SOC 2, etc.) ;
- S'assurer de la conformité au RGPD (notamment pour les transferts hors UE) ;
- Évaluer les risques résiduels liés au tiers.

Un **registre des tiers critiques** est tenu à jour par le RSSI et classifie les fournisseurs selon leur sensibilité (hébergement, traitement de données personnelles, interconnexion, etc.).

9.4 Fournisseurs cloud : exigences de sécurité

Les fournisseurs de services cloud utilisés par Logiclever (notamment Google Workspace, BoondManager, PayFit) doivent répondre aux critères suivants :

- **Plan de continuité d'activité (PCA)** formalisé et testé ;
- **Processus de réponse aux incidents** structuré (identification, containment, notification) ;
- Détention de **certifications de sécurité** reconnues :
    - ISO/IEC 27001 pour la sécurité des systèmes d'information ;
    - ISO 27018 pour la protection des données personnelles ;
    - ISO 22301 pour la continuité d'activité ;
    - SOC 2 type II le cas échéant.

- **Chiffrement des données** en transit et au repos ;
- Localisation des données **dans l'Union européenne** ou encadrée par clauses contractuelles types (SCCs) validées par le DPO ;

9.5 Évaluation périodique des risques liés aux fournisseurs cloud

Une **évaluation des risques SSI associés aux fournisseurs cloud** est réalisée **au moins une fois par an**, ou en cas de changement majeur (nouvel outil, modification contractuelle, incident). Cette évaluation s'appuie sur :

- Le **type de service fourni** (communication, gestion RH, stockage, reporting…) ;
- La **sensibilité des données traitées** ;
- Les garanties contractuelles et techniques apportées par le fournisseur ;
- Le **niveau de dépendance** vis-à-vis du service ;
- L'historique de performance et d'incidents.

Cette analyse aboutit à une **classification des risques fournisseurs** (faible, modéré, critique) et à la définition éventuelle de **mesures d'atténuation** (plan B, sauvegarde indépendante, double validation…).

10. Conformité et audit

La conformité aux exigences légales, réglementaires et normatives est un objectif structurant de la politique de sécurité des systèmes d'information de Logiclever. L'organisation s'engage à démontrer à tout moment la maîtrise de ses obligations en matière de sécurité, de protection des données, et à évaluer régulièrement l'efficacité de son dispositif SSI via des audits internes et externes.

10.1 Revue annuelle de la politique SSI

La politique SSI est **revue annuellement** par le RSSI, en collaboration avec la direction, le DPO et les parties prenantes concernées. Cette revue a pour objectifs :

- De vérifier l'adéquation de la politique avec l'évolution du contexte réglementaire, technologique et organisationnel ;
- D'intégrer les retours d'expérience issus des incidents de sécurité, des projets ou des audits ;
- De s'assurer que les responsabilités sont toujours bien attribuées et comprises ;
- De valider les nouveaux besoins de sensibilisation ou de mise à jour documentaire.

Le résultat de cette revue est présenté au **comité de pilotage SSI annuel**, qui statue sur les ajustements nécessaires.

Cette politique SSI est également revue systématiquement lors de changements organisationnels importants ou après un incident majeur.

10.2 Audits internes et contrôles périodiques

Des **audits internes SSI** sont organisés selon les besoins pour évaluer la conformité des pratiques et dispositifs aux exigences de la politique et aux référentiels de l'entreprise. Ils portent sur :

- Le respect des procédures d'accès, de gestion des incidents, des sauvegardes ;

- L’efficacité des mesures de protection des données personnelles ;
- L'application des exigences contractuelles vis-à-vis des tiers ;
- La cohérence entre les processus documentés et les pratiques effectives.

Chaque audit donne lieu à un rapport, avec :

- Les non-conformités ou écarts identifiés ;
- Les recommandations ;
- Le plan d’actions correctives avec responsable et échéancier.

Le RSSI centralise les rapports d’audit et en assure le suivi.

10.3 Suivi de la conformité réglementaire

Logiclever veille en permanence à rester conforme :

- Aux lois et règlements applicables (RGPD, Code du travail, Code de la consommation…) ;
- Aux obligations imposées par les autorités de contrôle (CNIL) ;
- Aux engagements contractuels passés avec les clients ou partenaires (clauses SSI, RGPD, niveaux de service) ;
- Aux recommandations sectorielles (ex. : guides de l’ANSSI).

Cette veille est assurée par le **DPO**, en lien avec le RSSI et, si besoin, la direction juridique. En cas d’évolution législative ou réglementaire, la documentation SSI est mise à jour et une **note d’information** est communiquée aux collaborateurs concernés.

10.4 Objectif de certification ISO/IEC 27001

Logiclever s’est engagé dans une **démarche de certification ISO/IEC 27001:2022**, visant à :

- Structurer son système de management de la sécurité de l'information (SMSI) ;
- Obtenir une reconnaissance externe de la maturité de sa démarche SSI ;

- Rassurer ses clients et partenaires sur la fiabilité de ses pratiques.

À cette fin, l'entreprise :

- A désigné un **RSSI responsable du SMSI** ;
- A s'engage à rédiger l'ensemble des documents exigés par la norme (politique, analyse de risques, procédures, registres…) ;
- Se prépare à un **audit de certification** par un organisme accrédité.

La certification permettra d'inscrire Logiclever dans une dynamique d'amélioration continue de la sécurité.

10.5 Documentation et traçabilité des preuves

Afin de démontrer sa conformité lors d'audits externes, d'appels d'offres ou de contrôles réglementaires, Logiclever maintient un **système de gestion documentaire SSI** incluant :

- La politique SSI à jour ;
- Les procès-verbaux du comité de pilotage SSI ;
- Les registres RGPD (traitements, demandes de droits, violations) ;
- Les preuves de sensibilisation et formation des utilisateurs ;
- Les résultats de revues d'habilitation, d'audits internes, de tests de sauvegarde ou de gestion des incidents ;
- Les contrats et annexes de sécurité avec les tiers.

Cette documentation est centralisée dans un espace sécurisé (drive restreint) et soumise à un cycle de conservation conforme aux exigences légales et contractuelles.

11 Politique d'usage acceptable - Charte informatique

Dans le cadre de la maîtrise des risques liés aux usages numériques, Logiclever a formalisé une **charte d'usage acceptable** destinée à encadrer les comportements attendus des utilisateurs vis-à-vis des ressources informatiques et numériques mises à leur disposition.

Cette charte a pour objectifs de :

- Protéger l'intégrité et la confidentialité du système d'information ;
- Sensibiliser les utilisateurs aux bonnes pratiques et obligations légales ;
- Éviter les abus, négligences ou usages non conformes (intentionnels ou non) ;
- Respecter les exigences de conformité RGPD et ISO/IEC 27001.

La charte d'usage s'applique à l'ensemble des utilisateurs disposant d'un accès au SI de Logiclever.

- La charte informatique est **remise à chaque nouvel arrivant** (employé ou prestataire) dès son intégration.
- Elle est **signée électroniquement ou physiquement**, et conservée dans le dossier RH ou projet.

12 indicateurs

Section PSSI	Indicateur	Valeur cible / seuil
2. Gouvernance & organisation SSI	Taux de réalisation du comité SSI	100 % / an
2. Gouvernance & organisation SSI	Taux de mise à jour de la politique SSI	≥ 1/an
3. Protection des données personnelles	Taux de complétude du registre des traitements	100 %
3. Protection des données personnelles	Taux de réponse aux demandes RGPD dans les délais	100 %
4. Sécurité des utilisateurs et RH	Taux de couverture des formations/sensibilisations annuelles	≥ 95 %
4. Sécurité des utilisateurs	Taux de vérification des antécédents	100 %

et RH		
5. Sécurité des systèmes d'information	Taux de traitement des vulnérabilités critiques dans les délais	100 %
5. Sécurité des systèmes d'information	Taux de mise à jour des systèmes internes	≥ 90 %
5. Sécurité des systèmes d'information	Taux de conformité de l'inventaire des actifs	≥ 95 %
6. Sécurité dans les projets	Nombre de projets ayant intégré une évaluation sécurité	100 % des projets critiques
8. Gestion des incidents	Délai moyen de traitement d'un incident de sécurité	< 48h
8. Gestion des incidents	Taux de documentation des incidents	100 %
9. Tiers & fournisseurs cloud	Taux de revue annuelle des fournisseurs critiques	100 %
9. Tiers & fournisseurs cloud	Taux de fournisseurs certifiés ISO 27001 ou équivalent	≥ 80 % des fournisseurs critiques
11. Charte informatique	Taux de collaborateur ayant signé la charte informatique	100 %

Les indicateurs sont compilés dans notre registre des indicateurs SSI.

Date de dernière mise à jour : 23/03/2026

Julien BOURLON
Président et DPO de Logiclever